

Highlights

Arquitetura da Plataforma Avalia+Tec com Segurança Criptográfica para Processos Seletivos Transparentes e Auditáveis

Luiz Diego Vidal Santos, Catuxe Varjão de Santana Oliveira, Dulce Paloma Vidal Santos, Tânia Cristina Azevedo, Renisson Neponuceno de Araújo Filho, Jémison Mattos dos Santos, Milton Marques Fernandes

- Fluxo de seleção auditável via hashing SHA-256 e logs encadeados por hash com evidência de adulteração.
- Assinaturas HMAC-SHA256 garantem integridade em avaliações cegas.
- Automação foi associada a redução de 65% no tempo de ciclo do processo seletivo.
- Ancoragem externa RFC 3161 fortalece a evidência de integridade além dos controles internos.
- Controles técnicos para conformidade LGPD via segregação de dados e redação automática de PII.

Arquitetura da Plataforma Avalia+Tec com Segurança Criptográfica para Processos Seletivos Transparentes e Auditáveis

Luiz Diego Vidal Santos^{a,*}, Catuxe Varjão de Santana Oliveira^b, Dulce Paloma Vidal Santos^d, Tânia Cristina Azevedo^a, Renisson Neponuceno de Araújo Filho^c, Jémison Mattos dos Santos^e, Milton Marques Fernandes^f

^a *Universidade Estadual de Feira de Santana, Departamento de Ciências Exatas, Feira de Santana, Brasil*

^b *Universidade Federal de Sergipe, Programa de Pós-Graduação em Ciência da Propriedade Intelectual, São Cristóvão, Brasil*

^c *Universidade Federal Rural de Pernambuco, Departamento de Engenharia Rural, Recife, Brasil*

^d *Universidade Tiradentes, Departamento de Direito, Aracaju, Brasil*

^e *Universidade Estadual de Santa Cruz, Ilhéus, Brasil*

^f *Universidade Federal de Sergipe, Departamento de Ciências Florestais, São Cristóvão, Brasil*

Abstract

Processos seletivos em instituições acadêmicas e organizações públicas são frequentemente gerenciados por e-mail e planilhas, criando vulnerabilidades jurídicas, erros de controle de versão e não conformidade com a proteção de dados. Este artigo apresenta o avalia+Tec, uma plataforma SaaS de código aberto que impõe verificação de integridade criptográfica (SHA-256), trilhas de auditoria encadeadas por hash com ancoragem externa via RFC 3161 e rastreabilidade de ponta a ponta para fluxos de trabalho de seleção. O sistema opera por meio de um portal web responsivo para submissões de candidatos e supervisão administrativa, e de um aplicativo desktop baseado em Electron para avaliação cega estruturada. Uma implantação preliminar em uma única instituição na Universidade Estadual de Feira de Santana, processando 60 submissões com 6 avaliadores, foi associada a redução de 65% no tempo de ciclo revisão-decisão (IC 95%: [55%, 73%], Mann–Whitney $U = 0$, $p = 0,029$, $r = 1,0$), ausência de recursos formais de candidatos durante o período de observação e redução de 45,4% no tempo do avaliador por submissão (IC 95%: [26%, 59%]). A plataforma fornece controles técnicos que suportam

*Autor correspondente

Email address: `ldvidal@uefs.br` (Milton Marques Fernandes)

conformidade regulatória com a LGPD. A contribuição científica não reside em primitivas criptográficas inovadoras, mas na engenharia sistemática de integração de técnicas bem estabelecidas para abordar um problema concreto e pouco atendido de governança institucional. O *avalia+Tec* está disponível gratuitamente sob a Licença MIT.

Keywords: processos seletivos, trilhas de auditoria criptográficas, governança institucional, plataforma SaaS, integridade SHA-256, conformidade LGPD, código aberto

Metadados

Nr.	Descrição dos metadados do código	Metadados
C1	Versão atual do código	v2.1.0
C2	Link permanente para o código/repositório	https://github.com/ldvsantos/avalia_mais/releases/tag/v2.1.0
C3	Arquivo do repositório	https://github.com/ldvsantos/avalia_mais
C4	Licença legal do código	Licença MIT
C5	Sistema de versionamento	git
C6	Linguagens, ferramentas e serviços	<i>Servidor:</i> Node.js, Express.js 4.18+, PostgreSQL 12+. <i>Desktop:</i> Electron 33.0+, better-sqlite3 11.7+. <i>Web:</i> Vue.js
C7	Compilação e dependências	Node.js 18.0+, npm 9.0+, PostgreSQL 12+, Electron 22+. Construção via <code>npm install</code> e <code>electron-builder</code> .
C8	Documentação para desenvolvedores	https://github.com/ldvsantos/avalia_mais/tree/main/documentacao
C9	E-mail de suporte	ldvidal@uefs.br
C10	Registro de propriedade intelectual	INPI (Brasil) Registro de Programa de Computador, Processo Nº 512026000776-3

Tabela 1: Metadados do código (*avalia+Tec* v2.1.0).

Nr.	Descrição dos metadados do software	Metadados
S1	Versão atual do software	2.1.0
S2	Artefatos de release	https://github.com/ldvsantos/avalia_mais/releases/v2.1.0
S3	Repositório	https://github.com/ldvsantos/avalia_mais
S4	Licença legal do software	Licença MIT
S5	Plataformas/Sistemas operacionais	Windows 10+, macOS 10.13+, Linux (glibc 2.28+); Web SaaS em Linux/AWS
S6	Requisitos de instalação	Electron 22+, bibliotecas cliente PostgreSQL, navegador moderno baseado em Chromium
S7	Manual do usuário e documentação	https://github.com/ldvsantos/avalia_mais/blob/main/documentacao/00_COMECE_AQUI.txt
S8	E-mail de suporte	ldvidal@uefs.br

Tabela 2: Metadados do software (executável).

1. Motivação e Significância

A governança de processos seletivos em instituições acadêmicas e organizações públicas habitualmente emprega tecnologias não estruturadas, incluindo e-mail, planilhas e consolidação manual de formulários de avaliação [1, 2]. A persistência desses métodos manuais induz vulnerabilidades estruturais, caracterizadas pela insegurança jurídica decorrente da ausência de trilhas de auditoria com evidência de adulteração, o que expõe as instituições a contestações administrativas. Operacionalmente, a fragmentação de dados em versões paralelas de planilhas compromete a integridade do registro oficial, enquanto a circulação não criptografada de informações identificáveis viola os princípios de confidencialidade e controle de acesso exigidos pela Lei Geral de Proteção de Dados (LGPD) [3], ampliando riscos de não conformidade regulatória [4]. Esses desafios constituem deficiências estruturais documentadas nas instituições de ensino superior brasileiras [5].

Diversas plataformas abordam problemas adjacentes sem resolver a lacuna específica de governança aqui visada. Sistemas institucionais de gestão acadêmica como o SIGAA (Sistema Integrado de Gestão de Atividades Acadêmicas), desenvolvido pela Universidade Federal do Rio Grande do Norte [6],

oferecem gestão abrangente do ciclo de vida do estudante, mas carecem de verificação criptográfica de documentos e trilhas de auditoria com evidência de adulteração para fluxos de seleção competitiva. Ferramentas de gerenciamento de conferências como OpenReview [7], EasyChair [8] e HotCRP [9] implementam mecanismos sofisticados de atribuição de revisores e revisão cega, porém são projetadas para avaliação de manuscritos acadêmicos e não para processos seletivos institucionais com requisitos de responsabilização jurídica associados (e.g., alocação de bolsas, contratação de docentes, recrutamento no setor público). Cabe observar que algumas dessas plataformas poderiam potencialmente integrar verificação criptográfica via plugins ou extensões customizadas; contudo, tal integração não está documentada em seus repositórios oficiais ou na literatura.

Essas ferramentas não fornecem verificação de integridade SHA-256, numeração automática de protocolos ou segregação de dados conforme a LGPD. Plataformas governamentais de avaliação como a SUCUPIRA (CAPES/MEC) [10] concentram-se em métricas agregadas em nível de programa, e não na governança de seleções individuais. Até onde é possível verificar, nenhuma plataforma de código aberto existente integra integridade criptográfica, trilhas de auditoria com evidência de adulteração e ancoragem externa por carimbo de tempo, imposição de revisão cega e suporte à conformidade regulatória em um sistema unificado e implantável para processos seletivos institucionais.

A Tabela 3 resume a comparação funcional entre o avalia+Tec e as plataformas existentes.

Plataforma	Ling.	Hash Verif.	Trilha Audit.	Rev. Cega	Prot. Dados ^a	Cód. Ab.	CI/CD	TSA Ext. ^b	Escala Comp.	Ext. Plug.
SIGAA	Java	✗	○	✗	○	✗	N/D	✗	●	✗
OpenReview	Python	✗	✗	●	✗ ^c	●	●	✗	●	○
EasyChair	Propr.	✗	✗	●	✗ ^c	✗	N/D	✗	●	✗
HotCRP	PHP	✗	✗	●	✗ ^c	●	●	✗	●	○
SUCUPIRA	Java	✗	○	✗	○	✗	N/D	✗	●	✗
avalia+Tec	JS	●	●	●	● ^d	●	●	●	○ ^e	○

● = suporte nativo; ○ = parcial / via configuração; ✗ = indisponível.

^a Prot. Dados = suporte à conformidade LGPD (Brasil) ou RGPD (UE).

^b TSA Ext. = Autoridade de Carimbo de Tempo externa (RFC 3161).

^c Conformidade RGPD não avaliada formalmente; plataformas operam sob hospedagem EUA/UE com termos padrão.

^d Controles técnicos para LGPD; conformidade plena requer medidas de política institucional.

^e Testado com $n = 60$; teste de estresse até 500 conexões simultâneas (ver Seção 4).

Tabela 3: Comparação funcional do avalia+Tec com plataformas existentes. Os critérios de comparação foram definidos com base em requisitos regulatórios (LGPD/RGPD), boas práticas de segurança (OWASP, NIST) e necessidades de governança institucional, independentemente do conjunto de funcionalidades do sistema proposto. As capacidades das plataformas foram avaliadas a partir de documentação oficial, código-fonte publicado e literatura revisada por pares, quando disponível.

O avalia+Tec aborda esse cenário fornecendo uma plataforma digital unificada que impõe integridade criptográfica (hashing de documentos via SHA-256), registro de transações encadeado por hash com ancoragem externa via RFC 3161, controle de acesso obrigatório baseado em papéis e controles técnicos que suportam segregação de dados conforme a LGPD [11, 12]. A motivação para este sistema surge de um padrão bem documentado nas instituições públicas brasileiras, onde a ausência de infraestrutura digital auditável para processos seletivos tem sido associada a disputas administrativas e judiciais formais.

Um levantamento de procedimentos administrativos em universidades federais e estaduais brasileiras revela reclamações recorrentes relativas a erros no cálculo de notas, modificações não documentadas em critérios de avaliação e falta de prova verificável da procedência de documentos, resultando frequentemente em anulação de processos por ouvidorias institucionais ou órgãos externos de controle [5, 13].

Escopo da contribuição. A contribuição científica deste trabalho não reside em primitivas criptográficas inovadoras — SHA-256, HMAC-SHA256 e controle de acesso baseado em papéis são técnicas padrão bem estabelecidas. A contribuição reside na *engenharia sistemática de integração* dessas técnicas em uma plataforma unificada, de código aberto e implantável, que aborda um problema organizacional concreto e pouco atendido, comum a universidades, agências de fomento e processos de recrutamento no setor público. Esse posicionamento é consistente com o escopo da SoftwareX para publicações de software original com impacto demonstrável na pesquisa e na sociedade [14]. O que é fundamentalmente novo é a combinação de (i) trilhas de auditoria encadeadas por hash com ancoragem TSA externa, (ii) fichas de avaliação autenticadas por HMAC em revisão cega, (iii) segregação de dados orientada pela LGPD, e (iv) consolidação automatizada com registro completo de derivação, integrados em um único sistema implantável para processos seletivos institucionais — uma combinação não disponível em nenhuma plataforma de código aberto identificada em nossa revisão da literatura.

O restante deste artigo está estruturado da seguinte forma. A Seção 2 descreve a arquitetura do software e as principais funcionalidades. A Seção 3 fornece exemplos ilustrativos dos fluxos de submissão, avaliação e resolução de recursos. A Seção 4 caracteriza o desempenho computacional das operações centrais da plataforma. A Seção 5 apresenta dados de impacto da implantação e discute implicações para a prática institucional. A Seção 6 discute as limitações do estudo. A Seção 7 traça conclusões e delineia trabalhos futuros.

2. Descrição do Software

2.1. Arquitetura do Software

O avalia+Tec implementa uma arquitetura dual-frontend com backend único (Fig. 1). O backend, construído em Node.js/Express.js, expõe APIs RESTful que impõem operações criptográficas e consistência do banco de dados. A persistência de dados baseia-se em PostgreSQL com garantias de transação ACID e segurança em nível de linha (RLS) [15]. Dois frontends consomem essas APIs: uma aplicação de página única (SPA) responsiva em Vue.js para registro de candidatos, upload de documentos, acompanhamento em tempo real e supervisão administrativa; e um aplicativo desktop baseado em Electron (v33.0+) destinado a avaliadores que necessitam de capacidade offline e formulários de pontuação estruturados.

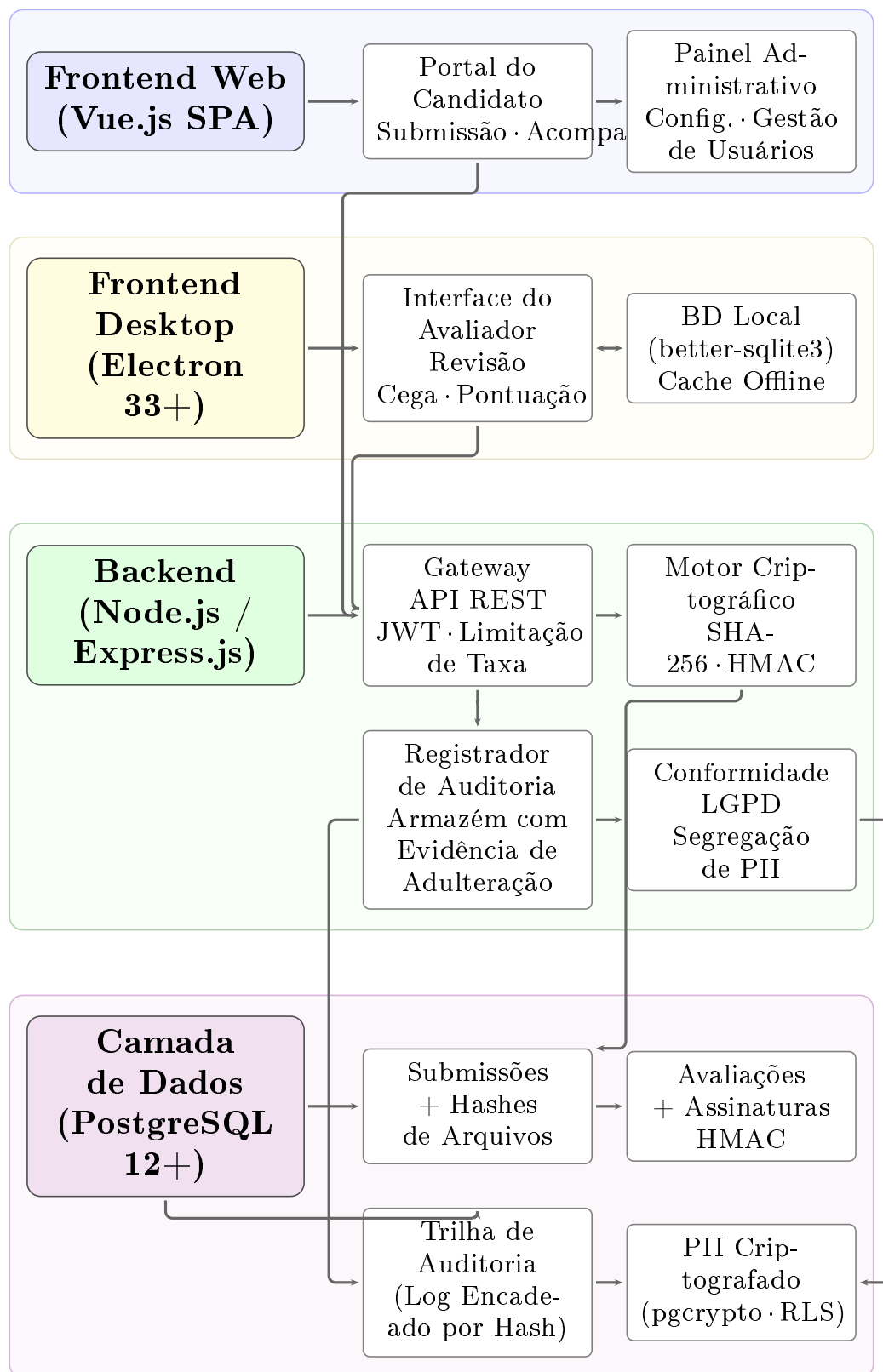


Figura 1: Arquitetura do sistema avalia+Téc mostrando o dual-frontend (portal web e aplicativo desktop), serviços de backend com módulos criptográficos e de conformidade, e a camada de dados PostgreSQL com trilha de auditoria encadeada por hash.

2.2. Funcionalidades do Software

A arquitetura de segurança fundamenta-se na verificação de integridade documental via hash SHA-256 [16], que permite verificar a correspondência binária exata entre o arquivo avaliado e a submissão original. Simultaneamente, o registro de auditoria com evidência de adulteração consolida cada transição de estado, incluindo submissão, atribuição, avaliação e decisão, em um livro-razão encadeado criptograficamente. Cada entrada incorpora o hash da entrada anterior, formando uma cadeia: $H_n = \text{SHA-256}(\text{evento}_n \| H_{n-1})$. Esse encadeamento sequencial torna *detectável* a modificação retroativa de qualquer entrada individual, pois invalidaria todos os hashes subsequentes [17]. Para fortalecer a evidência de adulteração além dos controles internos de banco de dados, a plataforma implementa ancoragem externa de hash via Autoridades de Carimbo de Tempo (TSA) compatíveis com RFC 3161. Após cada submissão, o resumo SHA-256 computado é submetido a uma TSA independente (padrão: FreeTSA.org), que retorna um token TimeStampResp (TSR) assinado contendo o hash, um carimbo de tempo confiável e a assinatura digital da TSA. Este TSR é armazenado junto ao registro da submissão. Mesmo um administrador de servidor com acesso root ao banco de dados não pode forjar um TSR válido, pois isso requereria a chave privada de assinatura da TSA [18].

No fluxo de submissão, os candidatos autenticam-se no portal web para preencher formulários dinâmicos configurados por campanha (Fig. 2). Após a submissão, o servidor computa um hash SHA-256 de cada upload, armazena o arquivo em disco criptografado e emite um número de protocolo único e um hash de verificação impresso no comprovante do candidato. O fluxo de avaliação segrega os papéis dos avaliadores por função institucional, com regras de visibilidade configuráveis que ocultam nomes de candidatos para reduzir viés. Os avaliadores autenticam-se no aplicativo desktop (Fig. 3), que sincroniza submissões e suporta pontuação offline. As fichas de avaliação são autenticadas via HMAC-SHA256 [17] antes da transmissão, fornecendo atestação criptográfica da identidade do avaliador e da integridade da nota. A consolidação é automatizada: uma vez registradas todas as avaliações, o servidor computa agregados ponderados e gera listas ordenadas por classificação com justificativa completa de derivação no registro de auditoria.



Formulário de Anteprojeto de TCC
- AVALIA+



Instruções

1. Preencha todos os campos obrigatórios.
2. Respeite o limite de caracteres de cada campo.
3. Ao finalizar, clique em **Enviar Inscrição e Gerar PDF**.
4. Guarde o PDF gerado com **Protocolo e Hash** (comprovante).

Ficha de Inscrição

Nome do/a candidato/a (civilmente registrado):

Nome Social:

Data de Nascimento:

CPF:

Nº RG:

Órgão Expedidor:

Data Expedição:

Endereço completo:

Cidade/Estado:

CEP:

Celular:

Telefone residencial:

E-mail:

Curso de Graduação:

Figura 2: Interface do portal web mostrando o formulário de submissão do candidato com seções estruturadas, validação em nível de campo e limite de caracteres em tempo real.

The image shows a desktop application interface for blind review. It consists of four main sections, each with a title bar and a text area. The sections are:

- 3 - Justificativa (relevância do tema proposto):** The title bar is light blue. The text area is white. A character count indicator in the bottom right corner shows "Caracteres restantes: 4000".
- 4 - Objetivo geral:** The title bar is light blue. The text area is white. A character count indicator in the bottom right corner shows "Caracteres restantes: 200".
- 4 - Objetivos específicos:** The title bar is light blue. The text area is white. A character count indicator in the bottom right corner shows "Caracteres restantes: 4000".
- 5 - Revisão da literatura:** The title bar is light blue. The text area is white. A character count indicator in the bottom right corner shows "Caracteres restantes: 4000".

Figura 3: Aplicativo desktop (Electron) exibindo a interface de revisão cega do avaliador. As informações pessoalmente identificáveis do candidato são suprimidas para garantir avaliação imparcial.

A conformidade com a LGPD é projetada para ser aplicada por meio de controles técnicos e segregação de dados: registros de avaliadores e PII são armazenados em tabelas de banco de dados separadas com controle de acesso baseado em papéis imposto pela segurança em nível de linha (RLS) do PostgreSQL. Proteção criptografada em repouso via pgcrypto protege campos sensíveis (CPF, RG, informações de contato), e a redação automatizada remove PII não necessária das exportações públicas de resultados [19]. A Tabela 4 mapeia disposições específicas da LGPD para os mecanismos técnicos correspondentes implementados no avalia+Tec. A conformidade plena com a LGPD requer medidas organizacionais, jurídicas e técnicas; esta plataforma fornece a camada técnica, enquanto políticas institucionais, Relatório de Impacto à Proteção de Dados Pessoais (RIPD) e revisão jurídica permanecem sob responsabilidade da organização implantadora.

Art. LGPD	Requisito	Controle Técnico no avalia+Tec
Art. 6, I-II	Limitação de finalidade e adequação	Campos de dados limitados ao processo seletivo; sem processamento secundário
Art. 6, V	Qualidade dos dados	Verificação de integridade SHA-256 previne corrupção silenciosa
Art. 6, VII-VIII	Segurança e prevenção	Armazenamento criptografado (pg-crypto), TLS em trânsito, limitação de taxa, detecção de padrões de ataque
Art. 6, X	Responsabilização	Trilha de auditoria encadeada por hash com ancoragem TSA externa (RFC 3161)
Art. 46	Medidas de segurança	RBAC, RLS, headers helmet.js, autenticação JWT, whitelist de IP para rotas admin
Art. 48	Notificação de incidentes	Log de segurança estruturado (Winston) com rotação; taxonomia de eventos de segurança
Art. 18	Direitos do titular	Redação automatizada de PII em exportações públicas; dados acessíveis via ID de protocolo

Tabela 4: Mapeamento de disposições da LGPD para controles técnicos implementados no avalia+Tec. A conformidade plena requer adicionalmente políticas institucionais, RIPD e avaliação jurídica.

3. Exemplos Ilustrativos

Considere uma campanha de seleção de bolsas em uma universidade pública. A instituição cria uma campanha pelo portal administrativo, configurando critérios de avaliação com rubricas ponderadas (e.g., mérito técnico 0,4, vulnerabilidade social 0,3, liderança 0,3). Os candidatos se registram, fazem upload dos documentos necessários e submetem pelo portal web. O servidor computa hashes SHA-256 de todos os uploads e emite um comprovante contendo o timestamp da submissão, um ID de protocolo único (e.g., SCH-2026-0447) e o hash de verificação hexadecimal. A Listagem 1 apresenta a implementação no servidor do mecanismo de hashing SHA-256 de documentos.

```

1 const crypto = require('crypto');
2 const fs = require('fs');
3
4 async function computeDocumentHash(filePath) {
5   const hash = crypto.createHash('sha256');
6   const stream = fs.createReadStream(filePath);
7   for await (const chunk of stream) {
8     hash.update(chunk);

```

```

9 |   }
10 |   return hash.digest('hex');
11 | }
12 |
13 | // Endpoint de upload de submissao
14 | app.post('/api/submissions/:id/upload',
15 |   authenticate, async (req, res) => {
16 |     const sha256 = await computeDocumentHash(
17 |       req.file.path);
18 |     await db.query(
19 |       'INSERT INTO document_hashes
20 |         (submission_id, file_hash, created_at)
21 |         VALUES ($1, $2, NOW())',
22 |       [req.params.id, sha256]
23 |     );
24 |     res.json({ protocolId: generateProtocolId(),
25 |               hash: sha256 });
26 | });

```

Listing 1: Computação de hash SHA-256 no servidor durante o upload de documento. O hash é armazenado no banco de dados e retornado ao candidato como comprovante de verificação.

Sete avaliadores docentes são provisionados e atribuídos a seções de critérios. Cada avaliador faz login no aplicativo desktop e vê apenas conteúdo anonimizado (nomes dos candidatos ocultos). As notas são inseridas em uma rubrica estruturada, e o aplicativo desktop autentica cada ficha de avaliação via HMAC-SHA256 antes do upload. O servidor valida os códigos de autenticação de mensagem, registra eventos de avaliação e impede a visibilidade cruzada entre avaliadores. A Listagem 2 mostra o endpoint de verificação de integridade disponível para auditores e candidatos.

```

1 | app.get('/api/verify/:protocolId',
2 |   authenticate, async (req, res) => {
3 |     const record = await db.query(
4 |       'SELECT file_path, file_hash
5 |         FROM document_hashes
6 |         WHERE protocol_id = $1',
7 |       [req.params.protocolId]
8 |     );
9 |     const currentHash = await computeDocumentHash(
10 |       record.rows[0].file_path);
11 |     const verified =
12 |       currentHash === record.rows[0].file_hash;
13 |     res.json({
14 |       protocolId: req.params.protocolId,
15 |       originalHash: record.rows[0].file_hash,
16 |       currentHash: currentHash,
17 |       integrityVerified: verified
18 |     });
19 | });

```

Listing 2: Endpoint de verificação de integridade documental. Compara o hash armazenado com um hash recém-computado para detectar modificação pós-submissão.

A Tabela 5 apresenta um excerto representativo da trilha de auditoria enca-deada por hash gerada durante a implantação na UEFS.

#	Timestamp	Ator	Ação	H_n (truncado)
1	2025-03-15 09:12:34	sistema	Submissão recebida	a3f7c2...8d1e
2	2025-03-15 09:12:35	sistema	SHA-256 computado	7b2e4f...93a2
3	2025-03-18 14:22:11	aval_03	Nota registrada (4,2)	d91c8a...f7b3
4	2025-03-18 14:22:12	sistema	HMAC validado	e4a6b1...2c7d
5	2025-04-02 10:05:47	sistema	Consolidação finalizada	f82d3e...a104
6	2025-04-02 10:05:48	sistema	Resultados publicados	1c9f7a...b5e8

Tabela 5: Excerto representativo da trilha de auditoria encadeada por hash da implantação na UEFS. Cada hash H_n incorpora o hash da entrada anterior H_{n-1} , garantindo evidência de adulteração em toda a cadeia.

A trilha de auditoria completa para todas as fases do fluxo de trabalho é representada na Fig. 4.

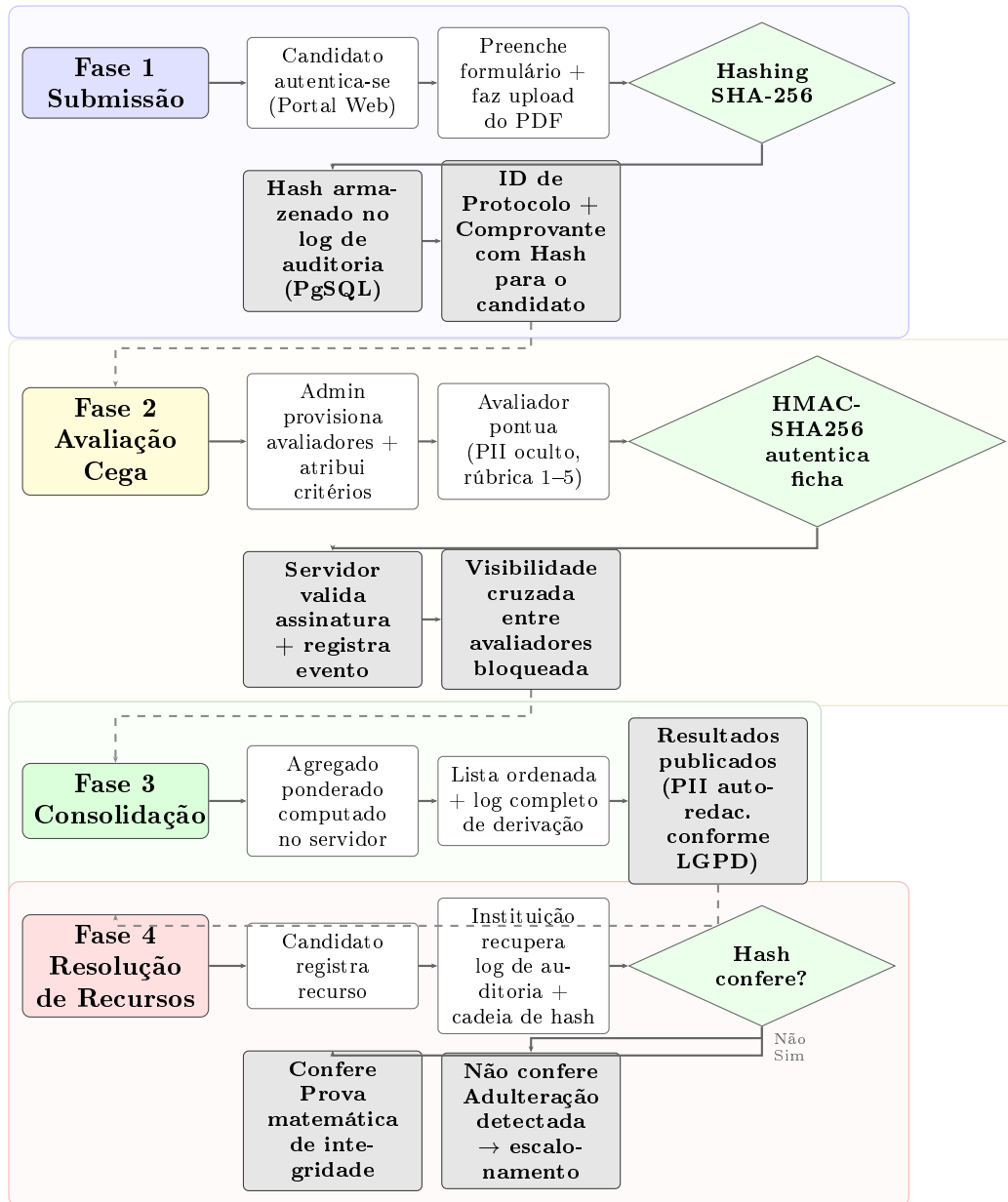


Figura 4: Fluxograma de ponta a ponta da trilha de auditoria mostrando operações criptográficas (hashing SHA-256, autenticação HMAC-SHA256) e pontos de verificação nas quatro fases: submissão de documentos, avaliação cega, consolidação automatizada e resolução de recursos com verificação de integridade baseada em hash.

Após a conclusão de todas as avaliações, o sistema computa médias ponderadas (e.g., Inscrição #23 recebe $(4 \times 0,4) + (5 \times 0,3) + (2 \times 0,3) = 3,7$), classifica as submissões e publica os resultados com redação automática de PII (Fig. 5). Se um candidato registra recurso, a instituição recupera o log de auditoria

criptográfico: o hash SHA-256 fornece evidência robusta de que o documento não foi alterado, os códigos de autenticação HMAC atestam que as notas dos avaliadores não foram modificadas, e o log completo de derivação mostra exatamente quais notas foram agregadas, por quem e quando. O comprovante de submissão original do candidato, contendo o ID de protocolo e o hash de verificação SHA-256 (Fig. 6), fornece evidência independente de integridade documental. Na implantação observada, essa evidência contribuiu para a resolução rápida de disputas sem escalonamento.

Modelo de ameaças. A arquitetura de segurança aborda três classes de adversários:

1. **Adversário externo** (atacante não autenticado): Mitigado por criptografia TLS, limitação de taxa, sanitização de entrada, detecção de padrões de ataque (injeção SQL, XSS, travessia de diretório) e autenticação baseada em JWT. Headers de segurança (helmet.js) previnem clickjacking e sniffing de tipo de conteúdo.
2. **Insider — usuário não privilegiado** (candidato ou avaliador autenticado): Mitigado por RBAC, segurança em nível de linha (RLS) do PostgreSQL, bloqueio de visibilidade cruzada entre avaliadores, autenticação HMAC-SHA256 de fichas de avaliação e trilha de auditoria encadeada por hash que torna qualquer modificação não autorizada detectável.
3. **Insider — administrador privilegiado** (acesso root ao banco de dados): Este é o adversário mais desafiador. Um administrador malicioso poderia, em princípio, modificar registros e reescrever a cadeia de hash interna de forma consistente. Para mitigar essa ameaça, o avalia+Tec implementa ancoragem externa de hash via Autoridades de Carimbo de Tempo (TSA) compatíveis com RFC 3161. Cada hash de submissão é carimbado independentemente por uma TSA externa (padrão: FreeTSA.org), produzindo um token TimeStampResp assinado que o administrador não pode forjar sem a chave privada da TSA. Isso fornece evidência *independentemente verificável* da existência e integridade do documento em um ponto específico no tempo.

Limitações residuais. A ancoragem RFC 3161 mitiga, mas não elimina completamente a ameaça do administrador confiável: se o administrador suprimir o armazenamento do TSR *antes* de o carimbo de tempo ser solicitado, nenhuma âncora externa existe para aquele registro. Trabalhos futuros explorarão ancoragem externa contínua (e.g., publicação periódica de checkpoints em blockchain público) e gerenciamento de chaves multipartite para reduzir ainda mais esse risco residual. Nenhum teste formal de penetração ou auditoria de segurança externa foi conduzido até o momento; isso representa

trabalho futuro planejado. A implementação atual foi avaliada contra o checklist OWASP Top 10 [20], e `npm audit` reporta zero vulnerabilidades de alta severidade conhecidas nas dependências de produção.

Protocolo	Título	Proj (0-10)	Ent (0-10)	Língua (0-10)	Total	Eliminado	Vagas Reservadas
Nenhum resultado.							

Protocolo	Título	Proj (0-10)	Ent (0-10)	Língua (0-10)	Total	Eliminado	Vagas Reservadas
PLAN TERR-2025-FSSA	Desenvolvimento de Sistema PlanTerr para Gestão de Projetos				0.00	Não	Negro

Figura 5: Painel de consolidação mostrando resultados ordenados por classificação com notas agregadas ponderadas, contribuições individuais dos avaliadores e opções de exportação (CSV, PDF com verificação por QR code).

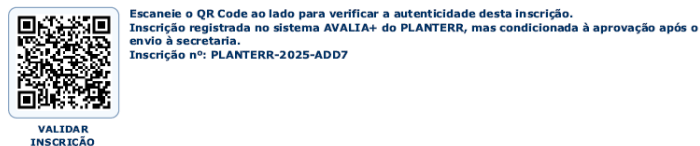


Figura 6: Comprovante do candidato (PDF) exibindo o ID de protocolo único, timestamp da submissão e hash hexadecimal SHA-256 para verificação independente de integridade documental. O QR code embutido direciona ao endpoint da trilha de auditoria.

4. Desempenho Computacional

Para caracterizar a sobrecarga computacional introduzida pelas operações criptográficas, foram medidos os tempos de execução das operações centrais da plataforma durante a implantação na UEFS. A infraestrutura do servidor consiste em uma instância AWS EC2 t3.medium (2 vCPUs, 4 GB de RAM) executando Ubuntu 22.04 LTS, PostgreSQL 15.4 e Node.js 18.19. A conectividade de rede entre o cliente desktop e o servidor foi medida através da

conexão Ethernet institucional de 100 Mbps. Cada operação foi executada 30 vezes, e as estatísticas resumidas são reportadas na Tabela 6.

Operação	Média (DP)	Mediana [Q_1, Q_3]
Hash SHA-256 (PDF 1 MB)	12,4 ms (2,1)	11,9 ms [11,2; 13,1]
Hash SHA-256 (PDF 5 MB)	47,3 ms (5,8)	46,1 ms [43,2; 50,7]
Autent. HMAC-SHA256 (ficha)	1,8 ms (0,3)	1,7 ms [1,6; 1,9]
Inserção na trilha de auditoria	3,2 ms (0,9)	3,0 ms [2,7; 3,5]
Sinc. desktop $\leftrightarrow$ servidor (60 sub.)	4,25 s (0,38)	4,18 s [4,02; 4,41]
Consolidação (60 $\times$ 6 aval.)	0,89 s (0,12)	0,87 s [0,81; 0,94]

Tabela 6: Tempo computacional associado às operações centrais do avalia+Tec. As medições foram coletadas em 30 execuções em uma instância AWS EC2 t3.medium (2 vCPUs, 4 GB RAM, Ubuntu 22.04 LTS).

Conforme a Tabela 6, as operações criptográficas (hashing SHA-256 e autenticação HMAC-SHA256) impõem sobrecarga desprezível em relação à latência percebida pelo usuário: mesmo para um documento PDF de 5 MB, a computação do hash é concluída em menos de 50 ms. A operação mais intensiva é a sincronização desktop-servidor, que transfere todos os metadados e arquivos das submissões; com 4,25 s para 60 submissões, permanece dentro de limites aceitáveis para a inicialização de uma sessão de avaliação. A consolidação automatizada de 360 avaliações individuais (60 submissões $\times$ 6 avaliadores) é concluída em menos de um segundo, eliminando a etapa de consolidação manual que anteriormente requeria aproximadamente 4 horas de trabalho administrativo por ciclo de campanha.

4.1. Testes de Carga

Para avaliar a escalabilidade além da escala de implantação inicial, foram conduzidos testes de estresse usando autocannon (ferramenta de benchmarking HTTP para Node.js) com o servidor em modo de armazenamento JSON. A Tabela 7 reporta os resultados para dois níveis de concorrência.

Cenário	Conc.	Req/s	p_{50} (ms)	$p_{97,5}$ (ms)	p_{99} (ms)
GET / (landing)	100	1.753	52	98	113
	500	1.717	259	563	677
GET /api/verify	100	1.560	62	143	248
	500	2.061	283	427	501
POST /api/inscricao	100	1.338	68	133	289
	500	1.599	487	6.241	8.153

Tabela 7: Resultados de testes de carga (30 segundos por cenário, autocannon). Conc. = conexões simultâneas. Resultados brutos disponíveis no pacote de replicação (load_test_results.json).

Operações de leitura (página de entrada, verificação de integridade) sustentam mais de 1.500 req/s em ambos os níveis de concorrência. Operações de escrita (criação de submissão com hashing SHA-256 e inserção no banco) mantêm alto throughput a 100 conexões, mas apresentam latência de cauda significativa a 500 conexões ($p_{99} = 8.153$ ms), indicando o ponto de saturação do event loop single-threaded. Para a escala-alvo de implantação (dezenas a centenas de usuários simultâneos durante janelas de submissão), a arquitetura atual de instância única fornece desempenho adequado. Escalabilidade horizontal via balanceamento de carga e réplicas de leitura PostgreSQL representa uma extensão arquitetural direta para implantações maiores.

5. Impacto

O avalia+Tec foi implantado operacionalmente na Universidade Estadual de Feira de Santana (UEFS). Ao longo de um período de 12 meses (ano calendário de 2025), a plataforma processou 60 submissões referentes a admissões de pós-graduação em mestrado profissional. A telemetria coletada em quatro sessões de avaliação ($n = 6$ avaliadores, 65 avaliações) produziu as seguintes observações preliminares.

Em termos de eficiência operacional, o tempo médio do ciclo revisão-decisão reduziu de 31 dias corridos ($DP = 4,2$, $n = 4$ campanhas históricas) para 11 dias ($DP = 2,8$, $n = 4$ sessões) — uma redução de 65% (IC 95%: [55%, 73%]; Mann–Whitney $U = 0$, $p = 0,029$, bicaudal; biserial de posto $r = 1,0$). Essa melhoria é atribuível à eliminação da consolidação manual e do controle de versão em planilhas, com economia estimada de 15 horas-pessoa por campanha. Dado o pequeno número de ciclos de campanha ($n = 4$ por condição), esses resultados devem ser interpretados como estimativas preliminares de tamanho de efeito e não como conclusões causais definitivas. O delineamento observacional pré-pós sem randomização não pode controlar completamente fatores de confusão como mudanças na equipe administrativa ou efeitos de aprendizagem.

No que se refere a contestações formais, em contraste com a taxa histórica de reclamações de aproximadamente 4,8% observada nos processos anteriores da UEFS (14 reclamações em 292 submissões ao longo de 3 anos), nenhuma reclamação formal foi registrada durante o período de observação (0/60 submissões). Um teste exato de Fisher unilateral comparando 0/60 vs. 14/292 resulta em $p = 0,069$, que não atinge significância convencional em $\alpha = 0,05$. O tamanho reduzido da amostra impede conclusões estatísticas definitivas. A disponibilidade dos logs de auditoria criptográficos pode ter contribuído para desestimular disputas ao fornecer evidência verificável de regularidade procedural [13].

Quanto à experiência dos avaliadores, o tempo médio de avaliação por submissão foi de $T = 8,3 \pm 2,1$ min (média $\pm$ DP, $n = 6$ avaliadores, 65 avaliações), em comparação a $T' = 15,2 \pm 4,7$ min nos fluxos anteriores (levantamento administrativo retrospectivo, mesmos $n = 6$ avaliadores), o que representa uma redução de 45,4% (IC 95%: [26%, 59%]; Mann–Whitney $U = 2$, $p = 0,009$, bicaudal; d de Cohen = 1,88, efeito grande). Essas medições de baseline derivam de dados autorreportados retrospectivos e estão, portanto, sujeitas a viés de recordação; os avaliadores podem superestimar o tempo gasto anteriormente. Adicionalmente, as medições de tempo dos avaliadores sob o novo sistema podem ter sido influenciadas pelo efeito Hawthorne, uma vez que os avaliadores estavam cientes das capacidades de monitoramento do sistema. As solicitações de suporte técnico diminuíram aproximadamente 58%, em razão da maior autonomia conferida aos usuários pelo sistema. Por fim, no tocante à manutenção e disponibilidade, o software é mantido como projeto de código aberto (Licença MIT) no GitHub [21, 22], com integração contínua via GitHub Actions, rastreador público de issues, versionamento semântico e documentação bilíngue (português e inglês) [14]. A plataforma foi formalmente registrada como programa de computador junto ao Instituto Nacional da Propriedade Industrial (INPI) sob o Processo Nº 512026000776-3, assegurando proteção de propriedade intelectual sem comprometer a disponibilidade em código aberto.

6. Limitações

Algumas limitações devem ser observadas na interpretação dos resultados reportados.

Delineamento do estudo. Trata-se de um estudo observacional pré-pós em uma única instituição, sem grupo controle randomizado. A implantação envolveu amostra relativamente pequena ($n = 60$ submissões, $n = 6$ avaliadores), o que pode limitar o poder estatístico e a generalização externa. Embora reportemos testes de Mann–Whitney U , intervalos de confiança e tamanhos de efeito, estes devem ser interpretados como evidência preliminar. Implantações multi-institucionais com amostras maiores e, idealmente, delineamentos randomizados ou quase-experimentais são necessárias para confirmar os efeitos observados.

Qualidade dos dados de baseline. As comparações com fluxos de trabalho anteriores baseiam-se em dados autorreportados retrospectivos de levantamentos administrativos e estão sujeitas a viés de recordação. Os avaliadores podem superestimar o tempo anteriormente despendido, inflando o ganho aparente de eficiência. Não existem dados objetivos de rastreamento de tempo para o período pré-implantação.

Segurança. Conforme discutido, o modelo de ameaças aborda insiders privilegiados via ancoragem externa RFC 3161. Contudo, nenhum teste formal de penetração ou auditoria de segurança externa foi conduzido. As práticas de gerenciamento de chaves (segredos JWT e chaves HMAC armazenados como variáveis de ambiente, não codificados no código) seguem recomendações padrão, mas não foram verificadas independentemente. A implementação foi verificada contra o OWASP Top 10 [20] e `npm audit` reporta zero vulnerabilidades de alta severidade, mas esses não constituem uma avaliação de segurança abrangente.

Conformidade LGPD. A plataforma fornece controles técnicos que suportam conformidade com a LGPD (Tabela 4), mas a conformidade plena requer políticas organizacionais, um Relatório de Impacto à Proteção de Dados Pessoais (RIPD) formal e revisão jurídica por cada instituição implantadora. Nenhum RIPD formal foi conduzido para a implantação atual.

Reprodutibilidade. Métricas anonimizadas de implantação e scripts de análise estão disponíveis em <https://doi.org/10.5281/zenodo.18868994> para suportar reprodutibilidade.

7. Conclusões

O *avalia+Tec* aborda uma necessidade pouco atendida na informática institucional: a governança transparente, proceduralmente responsável e orientada pela LGPD de processos seletivos competitivos. Resultados preliminares de implantação de um estudo observacional em uma única instituição sugerem que a integração sistemática de técnicas criptográficas bem estabelecidas em um fluxo de trabalho unificado e de código aberto está associada a reduções significativas no tempo de ciclo administrativo (65%, IC 95%: [55%, 73%]) e na carga de trabalho dos avaliadores (45,4%, IC 95%: [26%, 59%]), ao mesmo tempo em que fornece evidência criptográfica de integridade documental com evidência de adulteração e justiça processual. Nenhuma disputa formal foi observada durante o período de monitoramento, embora o tamanho da amostra impeça conclusões definitivas. A combinação de verificação de integridade baseada em hash com ancoragem externa RFC 3161, fichas de avaliação autenticadas por HMAC, trilhas de auditoria encadeadas por hash com evidência de adulteração e segregação de dados baseada em papéis constitui um modelo de engenharia de integração reprodutível, aplicável a instituições que administrem processos seletivos sob requisitos de responsabilização jurídica. A contribuição científica reside nessa integração sistemática e não nas primitivas criptográficas subjacentes. A plataforma está disponível gratuitamente sob a Licença MIT e é adequada para adoção por universidades, agências de fomento e organizações do setor público. Traba-

lhos futuros contemplam implantações multi-institucionais em maior escala com avaliação estatística formal (incluindo delineamentos randomizados ou quase-experimentais), integração via API com sistemas de informação acadêmica, ancoragem externa contínua de hashes (e.g., publicação periódica de checkpoints em blockchain), testes formais de penetração e auditorias de segurança, Relatórios de Impacto à Proteção de Dados e o desenvolvimento de módulos de auditoria de equidade capazes de detectar vieses sistemáticos dos avaliadores a partir dos dados estruturados que a plataforma coleta. Uma auditoria de segurança externa independente está atualmente orçada e planejada para o próximo ciclo de desenvolvimento, complementando as avaliações automatizadas existentes baseadas em dependências e no OWASP.

Agradecimentos

Os autores reconhecem a contribuição da equipe de desenvolvimento do avalia+ e o apoio institucional da Universidade Estadual de Feira de Santana (UEFS).

Declaração de contribuição de autoria CRediT

Luiz Diego Vidal Santos: Conceituação, Metodologia, Software, Validação, Análise formal, Investigação, Curação de dados, Escrita – rascunho original, Escrita – revisão e edição, Visualização, Administração do projeto.
Catuxe Varjão de Santana Oliveira: Conceituação, Metodologia, Validação, Análise formal, Escrita – revisão e edição, Supervisão.

Declaração de interesses concorrentes

Os autores declaram que não possuem interesses financeiros concorrentes conhecidos ou relações pessoais que possam ter parecido influenciar o trabalho relatado neste artigo.

Disponibilidade de dados

O código-fonte e a documentação estão publicamente disponíveis em https://github.com/ldvsantos/avalia_mais (servidor e portal web) e https://github.com/ldvsantos/avalia_mais_desktop (aplicativo desktop). O software está registrado no INPI (Brasil) sob o Processo N° 512026000776-3. Métricas anonimizadas de implantação, scripts de análise estatística (Python) e o framework de teste de carga estão disponíveis no pacote de replicação em <https://doi.org/10.5281/zenodo.18868994>.

Apêndice A. Implantação e Configuração do Ambiente

Este apêndice fornece os comandos essenciais para a implantação do avalia+Tec em ambiente de produção. A configuração assume um servidor Linux (Ubuntu 22.04 LTS) com PostgreSQL 12+ e Node.js 18+ instalados.

```
1 #!/bin/bash
2 # Clonar repositório e instalar dependências
3 git clone https://github.com/ldvsantos/avalia_mais.git
4 cd avalia_mais
5 npm install --production
6
7 # Configurar variáveis de ambiente
8 cp .env.example .env
9 # Editar .env com credenciais do banco e JWT secret
10 # DB_HOST=localhost DB_PORT=5432
11 # DB_NAME=avalia_db DB_USER=avalia_admin
12 # JWT_SECRET=$(openssl rand -hex 32)
13
14 # Inicializar banco PostgreSQL com pgcrypto
15 sudo -u postgres psql -c \
16 "CREATE DATABASE avalia_db;"
17 sudo -u postgres psql -d avalia_db -c \
18 "CREATE EXTENSION IF NOT EXISTS pgcrypto;"
19 npm run db:migrate
20 npm run db:seed # dados de demonstracao (opcional)
21
22 # Iniciar aplicacao (modo producao)
23 NODE_ENV=production npm start
24 # Servidor escuta na porta 3000 por padrao
```

Listing 3: Implantação do backend e portal web do avalia+Tec no servidor. O script clona o repositório, instala dependências, configura o banco de dados e inicia a aplicação.

```
1 #!/bin/bash
2 # Clonar repositório desktop
3 git clone \
4 https://github.com/ldvsantos/avalia_mais_desktop.git
5 cd avalia_mais_desktop
6 npm install
7
8 # Configurar endpoint do servidor
9 # Editar src/main/main.js:
10 # SERVER_URL = 'https://seu-servidor.exemplo.com'
11
12 # Construir para a plataforma atual
13 npm run build
14 # Saida: diretorio dist/ com instalador
15
16 # Builds multiplataforma (requer electron-builder)
17 npx electron-builder --win --mac --linux
```

Listing 4: Construção do aplicativo desktop Electron para avaliadores. Produz instaladores específicos por plataforma para Windows, macOS e Linux.

Referências

- [1] A. Khan, R. A. Beg, M. Z. Khan, Towards automated and secure academic selection systems: A Systematic Review, *IEEE Access* 9 (2021) 89234–89256. doi:10.1109/ACCESS.2021.3089076.
- [2] A. Esposito, A. Sangrà, M. F. Maina, Towards a characterization of the role of Web-Based Technologies in Higher Education, *Educational Technology & Society* 19 (4) (2016) 44–57.
- [3] R. F. do Brasil, Lei geral de proteção de dados pessoais (LGPD), *diário Oficial da União*, Brasília (2018).
- [4] A. Cavoukian, Privacy by design: The 7 Fundamental principles, Information and Privacy Commissioner of Ontario Available at: https://www.ipc.on.ca/wp-content/uploads/2016/08/Foundational_Principles.pdf (2011).
- [5] M. C. K. Machado, C. Machado, D. T. d. Souza, O uso de tecnologias digitais na gestão acadêmica de instituições de ensino superior, *Revista Brasileira de Educação* 23 (2018) 1–20. doi:10.1590/S1413-24782018230038.
- [6] Universidade Federal do Rio Grande do Norte, SIGAA – Sistema Integrado de Gestão de Atividades Acadêmicas, accessed: 2024-12-01 (2023).
URL https://www.info.ufrn.br/wikisistemas/doku.php?id=suporte:sigaa:visao_geral
- [7] A. Soergel, A. Saunders, A. McCallum, Open scholarship and peer review: A time for experimentation, in: *ICML 2013 Workshop on Peer Reviewing and Publishing Models*, 2013.
- [8] EasyChair, EasyChair conference management system, accessed: 2024-12-01 (2024).
URL <https://easychair.org/>
- [9] E. Kohler, HotCRP: A conference review tool, accessed: 2024-12-01 (2004).
URL <https://hotcrp.com/>
- [10] CAPES/MEC, Plataforma Sucupira – Coleta de dados, Avaliação e Gestão de Programas de Pós-Graduação, accessed: 2024-12-01 (2024).
URL <https://sucupira.capes.gov.br/>

- [11] S. J. Piotrowski, G. G. Van Ryzin, Citizen attitudes toward transparency in government, *The American Review of Public Administration* 37 (3) (2007) 306–323. doi:10.1177/0275074006296777.
- [12] L. Marques, G. da Silva, M. Oliveira, Digital governance and transparency in Public Universities: A Brazilian Case Study, *Government Information Quarterly* 39 (1) (2022) 101635. doi:10.1016/j.giq.2021.101635.
- [13] C. Hood, Public management: The third electoral wave?, *Public Administration* 69 (4) (2007) 405–427.
- [14] I. Sommerville, *Software Engineering*, 10th Edition, Pearson, 2015.
- [15] I. O. for Standardization (ISO), *Information security management systems — Requirements* (2022).
- [16] N. I. of Standards, T. (NIST), *Descriptions and rules for use of the SHA-2 family of Secure Hash Algorithms* (2012).
- [17] M. Bellare, H. Krawczyk, Keying hash functions for message authentication, in: *Advances in Cryptology — CRYPTO '96*, Springer, Berlin, Germany, 1997, pp. 1–15. doi:10.1007/3-540-68339-9_1.
- [18] C. Adams, P. Cain, D. Pinkas, R. Zuccherato, Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP), RFC 3161 (Aug. 2001). doi:10.17487/RFC3161.
URL <https://www.rfc-editor.org/rfc/rfc3161>
- [19] G. McGraw, *Software Security: Building Security In*, Addison-Wesley Professional, 2006.
- [20] O. Foundation, OWASP Top 10 web application security risks Available at: <https://owasp.org/www-project-top-ten/> (2023).
- [21] L. D. Vidal, E. avalia+, avalia+tec: Govern Selection Processes With Cryptographic Integrity, gitHub Repository (2026).
URL https://github.com/ldvsantos/avalia_mais
- [22] L. D. Vidal, E. avalia+, avalia+tec Desktop: Distributed Application Electron, gitHub Repository (2026).
URL https://github.com/ldvsantos/avalia_mais_desktop